

Security+ 4.8 · Incident Response

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.8 — Incident Response (9:14)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: NIST: Preparation → Detection/Analysis → Containment → Eradication → Recovery → Lessons Learned. Containment FIRST (isola antes de limpar). Lessons Learned alimenta a próxima Preparation.

Highlights que a prova cobra

- Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas
- CONTAINMENT primeiro: isola a propagação ANTES de limpar
- Lessons Learned alimenta novamente a Preparação

Dicas de prova & Cenários Típicos

- 'isolates affected systems to prevent spread'=Containment

Cenário clássico de exame: 'ataque detectado: primeira ação é isolar da rede'=containment.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.8 — Incident Response)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?

- A) Erradicação
- B) Preparação
- C) Recuperação
- D) Contenção

2. De acordo com o NIST, qual é a primeira fase do ciclo de resposta a incidentes?

- A) Detecção e Análise
- B) Preparação
- C) Contenção
- D) Recuperação

3. Em forense digital, o que é a cadeia de custódia (chain of custody)?

- A)** Tipo de criptografia de disco
- B)** Documentação do manuseio de evidências
- C)** Método de backup forense
- D)** Ferramenta de análise de malware

4. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições apre...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'CONTAINMENT primeiro: isola a propagação ANTES de limpar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: CONTAINMENT primeiro: isola a propagação ANTES de limpar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Lessons Learned alimenta novamente a Preparação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Lessons Learned alimenta novamente a Preparação...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'isolates affected systems to prevent spread'=Containment'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'isolates affected systems to prevent spread'=Containment...

8. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'ataque detectado: primeira ação é isolar da rede'=containment.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'ataque detectado: primeira ação é isolar da rede'=containment....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições apre...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Incident Response): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'CONTAINMENT primeiro: isola a propagação ANTES de limpar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: CONTAINMENT primeiro: isola a propagação ANTES de limpar...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Preparação.

✓ **Por que está certa:** De acordo com o NIST SP 800-61, o ciclo de resposta a incidentes é composto por quatro fases principais: Preparação; Detecção e Análise; Contenção, Erradicação e Recuperação; e Atividades Pós-Incidente. A primeira fase é a Preparação, que envolve estabelecer políticas, procedimentos, treinamento e ferramentas antes que um incidente ocorra. O CompTIA Security+ adota essa ordem e enfatiza que sem preparação adequada, as fases subsequentes são comprometidas. Portanto, 'Preparação' é o que vem primeiro.

✗ **Por que as outras estão erradas:**

- **Erradicação:** Erradicação é a fase em que se remove a causa raiz do incidente, como excluir malware ou corrigir vulnerabilidades. Ela ocorre após a contenção, não antes. No ciclo do NIST, a erradicação faz parte da terceira fase (Contenção, Erradicação e Recuperação). Portanto, não é a primeira etapa. A preparação deve preceder qualquer ação reativa.
- **Recuperação:** Recuperação é a fase de restaurar sistemas e dados ao estado normal de operação após a erradicação. É uma etapa posterior à contenção e erradicação. No NIST, a recuperação está incluída na terceira fase. Não pode ser a primeira, pois depende de ações anteriores de preparação, detecção e contenção.
- **Contenção:** Contenção é a fase de limitar o escopo e o impacto do incidente, evitando que se espalhe. É uma etapa crítica, mas ocorre após a detecção e análise, e antes da erradicação. No NIST, a contenção faz parte da terceira fase. A primeira fase é sempre a preparação, que antecede qualquer incidente. Portanto, contenção não é a primeira.

2) B — Preparação.

✓ **Por que está certa:** A alternativa correta é 'Preparação'. De acordo com o NIST SP 800-61 (Computer Security Incident Handling Guide), o ciclo de resposta a incidentes é composto por quatro fases: Preparação; Detecção e Análise; Contenção, Erradicação e Recuperação; e Atividades Pós-Incidente. A primeira fase, Preparação, é fundamental e ocorre antes que qualquer incidente aconteça. Ela envolve estabelecer políticas, procedimentos, treinamento de equipe, aquisição de ferramentas (SIEM, EDR, forense), definição de canais de comunicação e criação de planos de resposta. Sem uma preparação adequada, as fases subsequentes são comprometidas. O CompTIA Security+ enfatiza que a preparação é a base para uma resposta eficaz e que deve ser contínua, incluindo exercícios e simulações.

✗ **Por que as outras estão erradas:**

- **Detecção e Análise:** Esta é a segunda fase do ciclo de resposta a incidentes do NIST. Ela ocorre após a preparação e envolve monitorar, identificar e validar a ocorrência de um incidente, além de analisar seu escopo e impacto. Embora seja crucial, não é a primeira fase, pois depende de recursos, procedimentos e treinamento estabelecidos na preparação. A detecção e análise só podem ser eficazes se houver uma base preparada para coletar logs, correlacionar eventos e interpretar alertas.
- **Contenção:** A contenção faz parte da terceira fase do ciclo (Contenção, Erradicação e Recuperação). Seu objetivo é limitar o dano e impedir a propagação do incidente, isolando sistemas afetados. No entanto, a contenção só pode ser executada depois que o incidente foi detectado e analisado, e depende de planos e recursos definidos na fase de preparação. Portanto, não é a primeira fase, mas sim uma etapa reativa que ocorre durante o incidente.
- **Recuperação:** A recuperação também integra a terceira fase do ciclo, após a contenção e erradicação. Ela consiste em restaurar sistemas e serviços afetados ao estado normal de operação, validar que a ameaça foi eliminada e monitorar para garantir que não haja reinfecção. Assim como

a contenção, a recuperação é uma etapa posterior à detecção e análise e depende de uma preparação prévia, como backups e planos de continuidade. Não é a primeira fase do ciclo de resposta a incidentes.

3) B — Documentação do manuseio de evidências.

✓ **Por que está certa:** A cadeia de custódia (chain of custody) é o registro cronológico, documentado e auditável de todo o ciclo de vida da evidência digital: quem a coletou, quando, onde, como, sob quais condições, quem a manuseou, para onde foi transferida e como foi armazenada. No contexto forense, ela é o mecanismo que garante a integridade, autenticidade e admissibilidade da prova em juízo, permitindo rastrear qualquer pessoa que teve contato com o material e demonstrar que não houve adulteração, contaminação ou substituição. A CompTIA Security+ enfatiza que a cadeia de custódia é um requisito legal e processual, não uma ferramenta técnica, e que sua quebra pode invalidar toda a evidência.

✗ **Por que as outras estão erradas:**

- *Tipo de criptografia de disco:* Criptografia de disco é uma técnica de proteção de dados em repouso que codifica setores do disco rígido (ex.: BitLocker, LUKS, FileVault) para impedir acesso não autorizado caso o dispositivo seja perdido ou roubado. Ela não tem relação com a documentação do manuseio de evidências; é um controle de confidencialidade, enquanto a cadeia de custódia é um controle de integridade e responsabilidade legal. Portanto, confundir os dois conceitos desvia completamente do escopo forense.
- *Método de backup forense:* Backup forense refere-se à criação de uma cópia bit a bit (imagem forense) de uma mídia, preservando metadados e setores não alocados, frequentemente com ferramentas como dd, FTK Imager ou EnCase. Embora a imagem seja uma etapa importante da coleta, ela não é a cadeia de custódia em si; a cadeia é o registro documental que acompanha essa imagem e todas as ações subsequentes. Um backup sem documentação de custódia não tem valor probatório.
- *Ferramenta de análise de malware:* Ferramentas de análise de malware (ex.: IDA Pro, Ghidra, Cuckoo Sandbox) são utilizadas para engenharia reversa, análise comportamental e extração de indicadores de comprometimento. Elas pertencem à fase de exame ou análise forense, não à fase de preservação e documentação da evidência. A cadeia de custódia é um processo administrativo e legal que antecede e acompanha qualquer análise técnica, sendo independente do tipo de ferramenta utilizada.

4) B — Implementar a solução correspondente: Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições apre....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Response): Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: CONTAINMENT primeiro: isola a propagação ANTES de limpar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Response): CONTAINMENT primeiro: isola a propagação ANTES de limpar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Lessons Learned alimenta novamente a Preparação....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Response): Lessons Learned alimenta novamente a Preparação.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'isolates affected systems to prevent spread' = Containment....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Response): 'isolates affected systems to prevent spread' = Containment.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'ataque detectado: primeira ação é isolar da rede' = containment.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 4.8 (Incident Response): 'ataque detectado: primeira ação é isolar da rede'=containment..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições apre....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Response): Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: CONTAINMENT primeiro: isola a propagação ANTES de limpar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Response): CONTAINMENT primeiro: isola a propagação ANTES de limpar.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

